

Zenaian Internal Privacy Operations SOP

Final operational procedures for routine privacy, deletion, export, retention and incident handling

Final pre-implementation version 1.0 | August 14, 2026 | Repository snapshot d9137c605755

Final pre-implementation compliance specification. Operator/CPO placeholders remain for manual completion. Re-check Korean law in force on the actual launch date before publication.

1. Scope and roles

This SOP applies to the Zenaian website, extension, Render API/PostgreSQL, Clerk, xAI, Whop, planned Google Workspace privacy mailbox, and the public website host. [LEGAL OPERATOR NAME] is the controller for Zenaian-controlled processing. [CPO / PRIVACY RESPONSIBLE PERSON] owns this SOP after launch.

Internal response target for ordinary privacy requests: complete as soon as practicable and normally within 30 days. Product account-deletion automation has a stricter engineering target: initiate immediately and normally complete deletable active-system data within 24 hours, subject to provider outage/retry and lawful retention.

2. SOP-A - Account access / export request

1. Prefer authenticated self-service. User opens Account > Privacy > Export My Data. Require an active recent Clerk session; if risk signals exist, require reauthentication before export.
2. Create a `privacy_request_audit` row with request ID, HMAC subject reference, `type=export` and `received_at`. Do not store the export payload in the audit table.
3. Build the human-readable page from current Clerk profile, subscription/plan status, retained usage summaries, recent payment history, device-session summary, and applicable statutory archive entries linked to the authenticated subject.
4. Build downloadable JSON with the same categories and a metadata section explaining categories Zenaian does not retain (screenshots, prompts, answers). Do not include access/refresh tokens, session signing data, password/MFA secrets, raw webhooks, card/payment-method fields or provider credentials.
5. For local-only Chrome custom instruction, display: "Stored on this browser/device; not held in the Zenaian server export." Provide a local Clear control.
6. If a request arrives at `privacy@zenaian.com`, do not request a passport/ID by default. Direct the requester to authenticated self-service. If account access is impossible, verify using a proportionate combination such as control of the account email and non-secret transaction information.
7. If a former account holder requests retained transaction records, compute `subject_lookup_hmac` from the verified historical email and search only the segregated legal archive.
8. Log completion timestamp/outcome and automatically purge the request-audit row after one year unless an actual dispute/legal hold requires a documented extension.

3. SOP-B - Automated account deletion

User-facing effect

Deletion is immediate termination of Zenaian access. Any unused paid period/question allowance is forfeited. Future renewal is requested for cancellation. Deletion is not a refund request and does not waive mandatory withdrawal/refund rights.

9. Require a recent authenticated Clerk session and high-friction confirmation. User must tick: (a) access and unused allowance end immediately; (b) future renewal will be canceled/requested for cancellation; (c) narrow transaction

records required by law may remain separately for the statutory period; (d) deletion is irreversible. Require typed DELETE.

10. Create deletion request/audit state and immediately mark the user “privacy deletion blocked” so no new checkout, analysis, refresh or pairing can begin.
11. Cancel in-flight analysis jobs and clear any sensitive request body; settle/release quota reservations correctly.
12. Revoke all extension device sessions and delete pairing/session rows.
13. Load active Whop memberships/payment records and ensure statutory archive rows exist. If transaction archival is already event-driven, this step is a completeness check/upsert.
14. Remove Zenaian paid entitlement immediately. Call Whop cancel-at-period-end for any membership that would otherwise renew. The provider cancellation can be at period end because the purpose is to stop the future charge; Zenaian access itself ends immediately.
15. If Whop is temporarily unavailable, keep only the minimum provider ID/retry state needed to stop renewal. Do not reactivate the account. Retry automatically and escalate if not completed within the 24-hour target.
16. Delete operational billing records, usage rows, checkout rows and provider-event rows that are no longer needed for an active retry. Preserve only segregated statutory archive and the minimized deletion audit.
17. Delete the Clerk user using the Backend API only after local archival/block/provider-cancellation initiation has succeeded. If Clerk deletion fails, retry; the account remains blocked.
18. Return a deletion receipt/request ID in the current HTTP response. Do not send a marketing or reactivation email. The user may later contact privacy@zenaian.com about statutory records or mandatory consumer rights.
19. Completion means no ordinary user profile, live entitlement, device session, usage history, checkout state or current payment-history row remains in active Zenaian storage. Statutory archive and rolling recovery copies are exceptions.
20. If a Render backup is restored later, replay the privacy deletion ledger before restored data is exposed to production.

4. SOP-C - Correction request

21. Account name/email corrections should normally be performed through Clerk account controls.
22. If an operational billing mapping is wrong, correct the live mapping only after validating provider IDs; do not rewrite immutable historical payment facts.
23. If the segregated statutory archive contains an objectively incorrect fact, correct or annotate it while preserving evidence needed for legal accountability. Do not change a historical status merely because the user dislikes it.
24. Complete the request-audit record and notify the user of the result or lawful limitation.

5. SOP-D - Privacy email handling

25. Use privacy@zenaian.com only after Workspace is configured to the approved standard: Business Standard, US covered-data-at-rest region, enforced 2SV, no personal forwarding, 365-day auto-delete.
26. Triage messages into: rights request, account/security issue, consumer withdrawal/refund, complaint/dispute, general privacy question, or abuse/spam.
27. For authenticated-account actions, send the user to self-service rather than collecting extra identity documents by email.
28. For a legally relevant complaint/dispute, create a minimized complaint record with subject HMAC, provider transaction reference, category, dates and outcome; set 3-year statutory expiry where applicable. The email thread can still follow the 365-day mailbox rule.
29. Do not send screenshots/prompts to vendors via email during support unless strictly necessary and authorized; ask for redacted diagnostic information instead.

6. SOP-E - Statutory withdrawal / refund request

30. Identify whether the requester is a consumer and which mandatory law applies. For Korean consumers, start with E-Commerce Act Articles 17-18 rather than the discretionary “no-refund” policy.
31. Record contract date, service start, whether the legally required digital-content/immediate-service disclosure/measures were shown, amount charged, tax, usage/supply status, request date and reason.

32. If a valid statutory withdrawal applies, process the provider refund/cancellation without unnecessary delay. For services/digital content, Article 18 specifies a three-business-day refund period from the statutory trigger. [L4]
33. If the product/service differed from the advertisement or contract, apply the separate Article 17(3) window instead of the ordinary 7-day analysis. [L4]
34. If relying on the “service/digital content provision has begun” exception, verify that the Article 17(6) consumer-facing measures were actually implemented. If not, do not assume the exception is available.
35. Update statutory archive payment/withdrawal outcome and retain only the minimum record for the applicable legal period.
36. Account deletion is processed separately. A user may exercise a valid withdrawal right before or after deleting the Zenaian account.

7. SOP-F - Accidental sensitive-information submission

37. If no incident is reported during the live request, no special storage is created; content remains transient and ZDR.
38. If the user reports the issue while a job is still processing, cancel the job where feasible and clear the request body.
39. Do not copy the sensitive screenshot into an incident ticket, email, log or database. Record only a content-free incident code, time, systems involved and remediation.
40. Confirm xAI ZDR was active for the request using safe operational evidence. If ZDR was not confirmed, treat as a privacy incident and escalate immediately.
41. If exposure beyond the intended transient processors is suspected, invoke SOP-H breach response.

8. SOP-G - Scheduled retention maintenance

Cadence	Target	Procedure
Every 5 minutes / existing maintenance loop	Expired pairing/device sessions, stale reservations, Whop provider events	Use existing bounded cleanup pattern; add privacy purges without one unbounded transaction.
Daily	billing_analysis_usage >30d settled; usage_periods >90d after end; checkout failed/expired >7d; consumed >30d; terminal memberships >90d when statutory record complete	Delete in indexed batches.
Daily	live payment history older than 12 months when statutory record exists	Purge live copy; legal archive remains.
Daily	legal_retention.transaction_records past retention_expires_at	Hard delete in batches; record aggregate count only.
Daily	privacy_request_audit >1y after completion	Delete unless documented legal hold.
Quarterly	Vendor/subprocessor/retention review	Check xAI, Clerk, Render, Whop, Google, Hosting.kr terms/settings.
Before every release touching AI result UI	AI transparency regression check	Ensure advance notice and AI-generated marker remain.

9. SOP-H - Personal-information incident / breach

42. Contain first: revoke exposed credentials, block vulnerable route, preserve only necessary security evidence, and prevent further access.
43. Create an incident record without copying unnecessary personal content. Identify data categories, approximate data subjects, time window, cause, processors, and whether sensitive/unique identifiers were involved.
44. Notify internal CPO/privacy responsible person immediately.
45. Under the current PIPA Enforcement Decree, notification to affected data subjects is generally required within 72 hours after becoming aware of a qualifying leak, subject to the statutory exceptions. [L9]
46. Report to the PIPC/KISA within 72 hours when the reporting thresholds apply, including 1,000+ data subjects, sensitive/unique identifiers, or external unlawful access to a processing system/device, subject to the current decree. [L9]

47. If exact details are not yet known, issue the required preliminary notice/report with known information and supplement promptly as facts become available.
48. Contact the relevant processor under its incident/DPA channel. Do not delay a legally required Zenaian notice merely waiting for a vendor's final root-cause report.
49. After closure, document corrective action and determine whether the data/retention register or public policy needs revision.

10. SOP-I - xAI ZDR drift/failure

50. At deployment, verify the xAI team displays ZDR Active and save dated evidence.
51. Every production inference response must carry x-zero-data-retention:true. If the header is absent/false, treat the inference as failed, do not return/use the result, release quota where appropriate, and emit only a safe operational error code.
52. Automatically disable further production analysis until configuration is investigated if repeated ZDR failures occur.
53. Never fall back to ordinary xAI retention to preserve uptime.
54. If a personal-data request was sent while ZDR was not confirmed, assess whether it constitutes a privacy incident and document the result.

11. SOP-J - Provider / overseas-transfer change

55. Before adding or replacing a processor/subprocessor that materially changes personal-information handling, update the processing/transfer register.
56. For overseas processing, identify destination country, recipient/contact, data categories, timing/method, purpose and retention; verify the PIPA Article 28-8 route before production.
57. Update the Privacy Policy before or at the time required by law; do not silently add an analytics or profiling provider.
58. If a provider change increases retention or data categories, first ask whether the feature can operate without that increase.

12. SOP-K - Backup restore

59. Any Render PITR/logical-backup restoration is treated as a controlled recovery event.
60. Before routing production traffic to the restored DB, run migrations, replay all completed account-deletion/retention-purge markers newer than the restore point, and verify no deleted Clerk IDs have regained entitlement/session rows.
61. Do not restore screenshots/prompts because they should never exist in database backups.
62. Document the restore, deletion replay and verification result.

13. SOP-L - AI transparency check

- Website Terms, Chrome Web Store description, and a static extension popup/settings line state that Zenaian uses generative AI (xAI Grok) to produce proposed answers.
- Chrome action title/tooltip is the human-readable result marker: single "AI-generated answer: B"; multiple "AI-generated answers: A, C"; inconclusive "AI-generated result: inconclusive"; processing "Zenaian - AI processing".
- Release tests fail if advance notice disappears or any completed result path lacks the approved AI-generated title.

14. SOP-M - Hosting.kr website-host configuration

63. Use Hosting.kr only for public website hosting. Do not place the Zenaian application database, account/session store, screenshots, prompts, billing ledger or privacy-request database there.
64. In cPanel Metrics Editor, leave Webalizer, AWStats and Analog Stats disabled. They create visitor/traffic analytics that Zenaian has chosen not to use. [V22]

65. Leave automatic raw-access-log archiving disabled by default. Provider-native current raw logs may exist for hosting/security operations. If a specific incident requires a download, store the downloaded copy in restricted incident storage and delete it within 30 days unless a documented legal/security hold applies. [V21]
66. If temporary cPanel log archiving is enabled for a defined incident, enable removal of the previous month archived logs at month-end and disable archiving again after the incident.
67. If the webhosting service is intentionally terminated, use explicit Hosting.kr customer cancellation. Current Hosting.kr guidance says user-requested cancellation causes immediate deletion without its ordinary expiry grace/90-day long-backup recovery. [V23]
68. Treat the host as domestic Korean entrusted processing on current evidence. If later server-IP/provider documentation establishes an overseas hosting region, update the PIPA Article 28-8 register and Privacy Policy before relying on the new fact.

Source register

- [L1] **Korea Personal Information Protection Act (PIPA), current text.** <https://law.go.kr/LSW/IsInfoP.do?IsiSeq=270351>
- [L2] **PIPA Article 28-8 - overseas transfers.** <https://www.law.go.kr/LSW/IsLinkCommonInfo.do?chrClsCd=010202&IsJoLnkSeq=1029334737>
- [L3] **PIPC Privacy Policy Writing Guidelines, April 2026.** <https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS217&mCode=D010030000.Updated&nttlId=12018>
- [L4] **Korean E-Commerce Act Articles 17-18 - withdrawal and refunds.** <https://law.go.kr/LSW/IsLinkCommonInfo.do?chrClsCd=010202&IsJoLnkSeq=1013449821>
- [L5] **Korean E-Commerce Act Enforcement Decree Article 6 - transaction-record retention.** <https://www.law.go.kr/LSW/IsInfoP.do?IsiSeq=288143>
- [L6] **Korean Civil Act Articles 4-5 - majority and minors.** <https://www.law.go.kr/LSW/IsInfoP.do?IsiSeq=284415>
- [L7] **Korea AI Basic Act Article 31 - generative-AI transparency.** <https://www.law.go.kr/LSW/IsLinkCommonInfo.do?IsJoLnkSeq=1031809549>
- [L8] **Korea AI Basic Act Enforcement Decree Article 23 - disclosure/marketing methods.** <https://www.law.go.kr/IsLinkCommonInfo.do?IspttninfSeq=198075>
- [L9] **PIPA Enforcement Decree Articles 39-40 - 72-hour breach notice/reporting.** <https://www.law.go.kr/LSW/IsLawLinkInfo.do?chrClsCd=010202&IsJoLnkSeq=1000089686>
- [V1] **xAI API Security FAQ - Zero Data Retention.** <https://docs.x.ai/developers/faq/security>
- [V2] **xAI Enterprise Terms.** <https://x.ai/legal/terms-of-service-enterprise>
- [V3] **xAI DPA.** <https://x.ai/legal/data-processing-addendum>
- [V4] **xAI Subprocessor List.** <https://x.ai/legal/subprocessor-list>
- [V5] **Render Regions.** <https://render.com/docs/regions>
- [V6] **Render Logs.** <https://render.com/docs/logging>
- [V7] **Render Postgres Recovery and Backups.** <https://render.com/docs/postgresql-backups>
- [V8] **Clerk DPA.** <https://clerk.com/legal/dpa>
- [V9] **Clerk deleteUser API.** <https://clerk.com/docs/reference/backend/user/delete-user>
- [V10] **Whop Seller Terms - incorporates Seller Data Sharing Addendum.** <https://whop.com/seller-terms/>
- [V11] **Whop legal-document upload and acceptance controls.** <https://docs.whop.com/manage-your-business/manage-business/legal-documents>
- [V12] **Whop Payment API.** <https://docs.whop.com/api-reference/payments/retrieve-payment>
- [V13] **Whop Membership API.** <https://docs.whop.com/api-reference/memberships/retrieve-membership>
- [V14] **Whop Privacy Policy.** <https://whop.com/privacy/>
- [V15] **Google Workspace Data Regions.** <https://support.google.com/a/answer/14310028>
- [V16] **Google Workspace Gmail Auto-Delete.** <https://support.google.com/a/answer/151128>
- [V17] **Google Workspace 2-Step Verification.** <https://support.google.com/a/answer/175197>
- [V18] **Google Workspace Subprocessors.** <https://workspace.google.com/terms/subprocessors/>
- [V19] **Hosting.kr / Megazone Privacy Policy.** <https://www.hosting.kr/policies/privacy>

[V20] Hosting.kr Linux webhosting - AWS-based hosting environment. <https://www.hosting.kr/webhosting>

[V21] Hosting.kr Raw Access log controls. <https://help.hosting.kr/hc/ko/articles/900005240146>

[V22] Hosting.kr Metrics Editor - Webalizer / Analog / AWStats controls.
<https://help.hosting.kr/hc/ko/articles/900006193483>

[V23] Hosting.kr cancellation / deletion and long-backup behavior.
<https://help.hosting.kr/hc/ko/articles/4408216133529>

[V24] Whop Seller Data Sharing Addendum - incorporated by reference in Seller Terms; public Seller Terms provide the controlling incorporation point. <https://whop.com/seller-terms/>